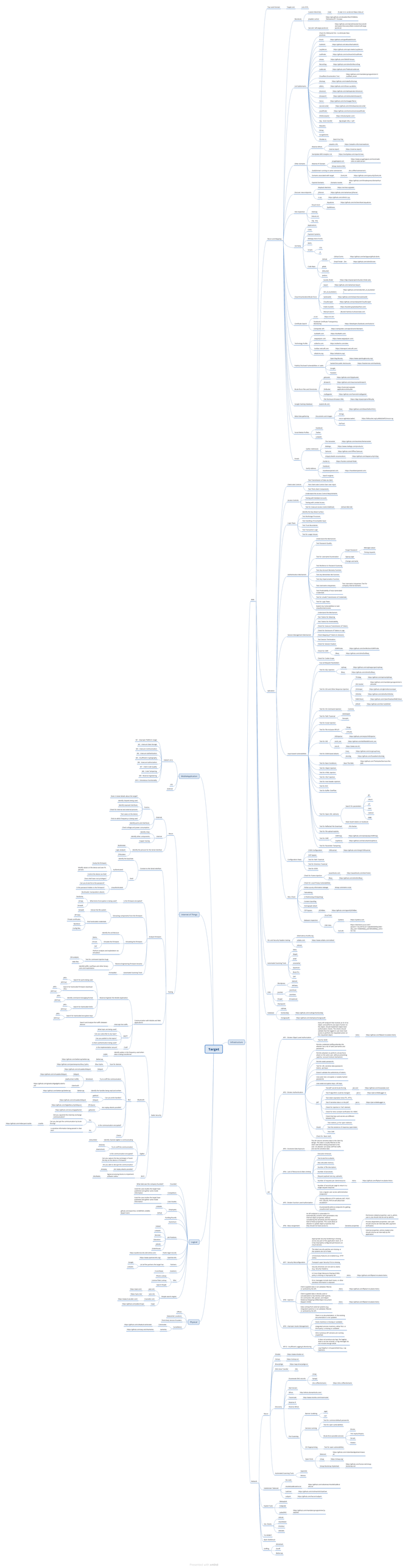

Target

- Infrastructure
  - Web
    - Top Level Domain
      - Target.com
        - List of IPs
    - Recon and Mapping
      - WordLists
        - Custom Word lists
          - Cewl
            - $ cewl -m 4 -w dict.txt https://site.url
        - JHaddix's all.txt
          - https://gist.github.com/jhaddix/f64c97d0863a78454e44c2f7119c2a6a
        - SecLists' raft-large-words.txt
          - https://github.com/danielmiessler/SecLists/blob/master/Discovery/Web-Content/raft-large-words.txt
      - List Subdomains
        - Check for Wildcards first - to eliminate false positives
        - knock
          - https://github.com/guelfoweb/knock
        - Sublist3r
          - https://github.com/aboul3la/Sublist3r
        - LazyRecon
          - https://github.com/capt-meelo/LazyRecon
        - subfinder
          - https://github.com/ice3man543/subfinder
        - amass
          - https://github.com/OWASP/Amass
        - ReconDog
          - https://github.com/s0md3v/ReconDog
        - subbrute
          - https://github.com/TheRook/subbrute
        - Cloudflare Enumeration Tool
          - https://github.com/mandatoryprogrammer/cloudflare_enum
        - dnsmap
          - https://github.com/makefu/dnsmap
        - altdns
          - https://github.com/infosec-au/altdns
        - dnsrecon
          - https://github.com/darkoperator/dnsrecon
        - dnssearch
          - https://github.com/evilsocket/dnssearch
        - Fierce
          - https://github.com/mschwager/fierce
        - second-order
          - https://github.com/mhmdiaa/second-order
        - assetfinder
          - https://github.com/tomnomnom/assetfinder
        - DNSDumpster
          - https://dnsdumpster.com/
        - Dig - Zone transfer
          - dig [target URL] -r axfr
        - Massdns
        - Nmap
        - GoogleDorks
        - Shodan.io
          - Search by Org:
      - Other domains
        - Reverse Whois
          - viewdns info
            - https://viewdns.info/reversewhois/
          - reverse.report
            - https://reverse.report/
        - Nerdydata With Analytics UA
          - https://nerdydata.com/reports/new
        - Reverse IP Domain
          - yougetsignal.com
            - https://www.yougetsignal.com/tools/web-sites-on-web-server/
          - Nmap reverse DNS
        - (Sub)Domain running on same nameserver
          - dns.coffee/nameservers
        - Domains associated with target
          - DomLink
            - https://github.com/vysecurity/DomLink
        - Expired Domains
          - Domains Hunter
            - https://github.com/threatexpress/domainhunter
      - Discover new endpoints
        - Wayback Machine
          - https://archive.org/web/
        - JSParcer
          - https://github.com/nahamsec/JSParser
        - cc.py
          - https://github.com/si9int/cc.py
      - Site Inspection
        - Visual recon
          - Aquatone
            - https://github.com/michenriksen/aquatone
          - EyeWitness
        - Sitemap
        - Robots.txt
        - Dig - Any
      - 3rd Party
        - Applications
        - CDNs
        - Payment Systems
        - Webapp Store Fronts
        - WAFs
        - Scripts
          - CSS
          - .js
        - Code Repo
          - GitHub
            - Github Dorks
              - https://github.com/techgaun/github-dorks
            - Email Finder - Zen
              - https://github.com/s0md3v/zen
          - gitlab
          - bitbucket
          - Jenkins
      - Cloud Enumeration/Brute Force
        - bucket_finder
          - https://digi.ninja/projects/bucket_finder.php
        - lazys3
          - https://github.com/nahamsec/lazys3
        - teh_s3_bucketeers
          - https://github.com/tomdev/teh_s3_bucketeers
        - Sandcastle
          - https://github.com/0xSearches/sandcastle
        - CloudScraper
          - https://github.com/jordanpotti/CloudScraper
        - Public buckets
          - https://buckets.grayhatwarfare.com/
        - Manual search
          - [Bucket Name].s3.amazonaws.com
      - Certificate Search
        - crt.sh
          - https://crt.sh/
        - Facebook Certificate Transparency Monitoring
          - https://developers.facebook.com/tools/ct/
        - Certspotter API
          - https://certspotter.com/api/v0/certs?domain=
      - Technology Profile
        - builtwith.com
          - https://builtwith.com/
        - wappalyzer.com
          - https://www.wappalyzer.com/
        - w3techs.com
          - https://w3techs.com/sites
        - toolbar.netcraft.com
          - https://sitereport.netcraft.com/
        - whatcms.org
          - https://whatcms.org/
      - Publicly Disclosed Vulnerabilities or Leaks
        - Open Bug Bounty
          - https://www.openbugbounty.org/
        - hackerOne public disclosures
          - https://hackerone.com/hacktivity
        - Google
        - Pastebin
      - Brute-force Files and Directories
        - gobuster
          - https://github.com/OJ/gobuster
        - dirsearch
          - https://github.com/maurosoria/dirsearch
        - DirBuster
          - https://tools.kali.org/web-applications/dirbuster
        - snallygaster
          - https://github.com/hannob/snallygaster
        - File Disclosure Browser (fdb)
          - https://digi.ninja/projects/fdb.php
      - Google Hacking Database
        - exploit-db.com
      - Meta Data gathering
        - Documents and Images
          - Foca
            - https://github.com/ElevenPaths/FOCA
          - Strings
          - recon-ng(metacrawler)
            - https://bitbucket.org/LaNMaSteR53/recon-ng
          - Exif tool
      - Social Media Profiles
        - Facebook
        - Twitter
        - LinkedIn
      - Emails
        - Gather Addresses
          - The Harvester
            - https://github.com/laramies/theHarvester
          - Maltego
            - https://www.maltego.com/products/
          - Samurai
            - https://github.com/OffXec/Samurai
          - InSpy(LinkedIn enumeration)
            - https://github.com/leapsecurity/InSpy
        - Verify Address
          - Hunter.io
            - https://hunter.io/email-finder
          - Facebook
          - haveibeenpwned.com
            - https://haveibeenpwned.com/
          - Search engines
    - Aplication
      - Client-side Controls
        - Test Transmission of Data via client
        - Test Client-side Control Over User Input
        - Test Thick-client Components
      - Access Controls
        - Understand the Access Control Requirements
        - Testing with Multiple Accounts
        - Testing with Limited Access
        - Test for Insecure Access Control Methods
          - GitHub Wiki Edit
      - Logic Flaws
        - Identify the Key Attack Surface
        - Test Multistage Processes
        - Test Handling of Incomplete Input
        - Test Trust Boundaries
        - Test Transaction Logic
        - Test for usage misuse
      - Authentication Mechanism
        - Understand the Mechanism
        - Test Password Quality
        - Test for Username Enumeration
          - Forgot Password
            - Message output
            - Timing requests
          - Signup page
          - Change username
        - Test Resilience to Password Guessing
        - Test Any Account Recovery Function
        - Test Any Remember Me Function
        - Test Any Impersonation Function
        - Test Username Uniqueness
          - Test Username Uniqueness Test for company internal domains
        - Test Predictability of Auto-Generated Credentials
        - Test for Unsafe Transmission of Credentials
        - Test for Logic Flaws
        - Exploit Any Vulnerabilities to Gain Unauthorized Access
      - Session Management Mechanism
        - Understand the Mechanism
        - Test Tokens for Meaning
        - Test Tokens for Predictability
        - Check for Insecure Transmission of Tokens
        - Check for Disclosure of Tokens in Logs
        - Check Mapping of Tokens to Sessions
        - Test Session Termination
        - Check for Session Fixation
        - Check for CSRF
          - XSRFProbe
            - https://github.com/0xInfection/XSRFProbe
          - Blazy
            - https://github.com/s0md3v/Blazy
        - Check for Cookie Scope
      - Input-based Vulnerabilities
        - Fuzz all Request Parameters
        - Test for SQL Injection
          - sqlmap
            - https://github.com/sqlmapproject/sqlmap
          - Blazy
            - https://github.com/s0md3v/Blazy
        - Test for XSS and Other Response Injection
          - TPLMap
            - https://github.com/epinna/tplmap
          - XSS Hunter
            - https://github.com/mandatoryprogrammer/xsshunter
          - XSSSniper
            - https://github.com/gbrindisi/xsssniper
          - XSStrike
            - https://github.com/s0md3v/XSStrike
          - RABCDAsm
            - https://github.com/CyberShadow/RABCDAsm
          - JSShell
            - https://github.com/Den1al/JSShell
        - Test for OS Command Injection
          - Commix
        - Test for Path Traversal
          - dotdotpwn
          - Panoptic
        - Test for Script Injection
        - Test for File Inclusion RFI/LFI
          - fimap
          - LFISuite
        - Test for XXE
          - XXEinjector
            - https://github.com/enjoiz/XXEinjector
          - oxml_xxe
            - https://github.com/BuffaloWill/oxml_xxe
          - xxe.sh
            - https://www.xxe.sh/
        - Test for DOM based attacks
          - tracy
            - https://github.com/nccgroup/tracy
          - domdig
            - https://github.com/fcavallarin/domdig
        - Test for Race Conditions
          - Race The Web
            - https://github.com/TheHackerDev/race-the-web
        - Test for Object Injection
        - Test for HTML Injection
        - Test for CRLF Injection
        - Test for Host header injection
        - Test for RCE
        - Test for Buffer Overflow
        - Test for Open URL redirects
          - Search for parameters
            - go
            - return
            - url
            - next
            - redirect
            - page
          - Steal OAuth tokens on Facebook
        - Test for Reflected File Download
          - rfd-checker
        - Test for File upload exploits
        - Test for SSRF
          - SSRFmap
            - https://github.com/swisskyrepo/SSRFmap
          - Gopherus
            - https://github.com/tarunkant/Gopherus
        - Test for Parameter Tampering
      - Configuration Flaws
        - CORS Configuration
          - ORScanner
            - https://github.com/chenjj/CORScanner
        - SOP bypass
        - Test for Path Traversal
        - Test for Directory Traversal
        - Test for IDOR
      - Misc Check
        - Check for Frame Injection
          - savanttools.com
            - http://savanttools.com/test-frame
          - Blazy
            - https://github.com/s0md3v/Blazy
        - Check for Local Privacy Vulnerabilities
        - Follow up any information leakage
          - Nmap comments script
        - Tabnabbing
        - UI Redressing (Clickjacking)
        - Content Spoofing
        - Homograph attack
        - CSP bypass
          - JSONBee
            - https://github.com/zigoo0/JSONBee
        - Malware Inspection
          - VirusTotal
          - CMS Sites
            - Quttera
              - https://quttera.com
            - SUCURI
              - https://sitecheck.sucuri.net/?cjevent=11bc24974ccd11ea828500e90a240612&cj_aid=13948096&cj_pid=8092889&cj_cid=4761150
    - SSL and Security headers testing
      - observatory.mozilla.org
      - ssllabs.com
        - https://www.ssllabs.com/ssltest/
      - sslscan
    - Automated Scanning Tools
      - Nikto
      - Wapiti
      - w3af
      - sonarwhal
      - lazyrecon
      - Burp Pro
      - ZAP
    - CMS
      - Wordpress
        - wpscan
        - WPSeku
      - Joomla!
        - JoomScan
        - joomlavs
      - Drupal
        - droopescan
      - Sharepoint
    - Database
      - sqlmap
      - NoSQLMap
        - https://github.com/codingo/NoSQLMap
      - mongoaudit
        - https://github.com/stampery/mongoaudit
    - API
      - API1 - Broken Object Level Authorization
        - Every API endpoint that receives an ID of an object, and performs any type of action on the object, should implement object level authorization checks. The checks should validate that the logged-in user does have access to perform the requested action on the requested object.
          - Astra
            - https://github.com/flipkart-incubator/Astra
        - Test for IDOR
      - API2 - Broken Authentication
        - Permits credential stuffing whereby the attacker has a list of valid usernames and passwords
        - Permits attackers to perform a brute force attack on the same user, without presenting captcha / account lockout mechanism
        - Permits weak passwords
        - Test for URL sensitive data (password, tokens, api keys)
        - Doesn't validate the authenticity of tokens
        - Uses plain text, encrypted, or weakly hashed passwords
        - Uses weak encryption keys / API keys
        - JWT
          - Test JWT secret brute-forcing
            - jwt_tool
              - https://github.com/ticarpi/jwt_tool
          - Test if algorithm could be changed
            - jwt.io
              - https://jwt.io/#debugger-io
          - Test token expiration time (TTL, RTTL)
          - Test if sensitive data is in the JWT
            - jwt.io
              - https://jwt.io/#debugger-io
          - Check for Injection in "kid" element
          - Check for time constant verification for HMAC
          - Check that keys and secrets are different between ENV
        - OAuth
          - Test redirect_uri for open redirects
          - Test the existence of response_type=token
          - Test CSRF
        - Check for Basic Auth
      - API3 - Excessive Data Exposure
        - The API returns sensitive data to the client by design. This data is usually filtered on the client side before being presented to the user. An attacker can easily sniff the traffic and see the sensitive data
      - API4 - Lack of Resources & Rate Limiting
        - Execution timeouts
        - Test brute-force attacks
        - Max allocable memory
        - Number of file descriptors
        - Number of processes
        - Request payload size (e.g. uploads)
        - Number of requests per client/resource
          - Astra
            - https://github.com/flipkart-incubator/Astra
        - Number of records per page to return in a single request response
      - API5 - Broken Function Level Authorization
        - Can a regular user access administrative endpoints?
        - Testing different HTTP methods (GET, POST, PUT, DELETE, PATCH) will allow level escalation?
        - Enumerate/Bruteforce endpoints for getting unauthorized requests
      - API6 - Mass Assignment
        - An API endpoint is vulnerable if it automatically converts client parameters into internal object properties, without considering the sensitivity and the exposure level of these properties. This could allow an attacker to update object properties that they should not have access to.
          - Sensitive properties
            - Permission-related properties: user.is_admin, user.is_vip should only be set by admins.
            - Process-dependent properties: user.cash should only be set internally after payment verification.
            - Internal properties: article.created_time should only be set internally by the application.
      - API7 - Security Misconfiguration
        - Appropriate security hardening is missing across any part of the application stack, or if it has improperly configured permissions on cloud services.
        - The latest security patches are missing, or the systems are out of date.
        - Unnecessary features are enabled (e.g., HTTP verbs).
        - Transport Layer Security (TLS) is missing.
        - Security directives are not sent to clients (e.g., Security Headers).
        - A Cross-Origin Resource Sharing (CORS) policy is missing or improperly set.
          - Astra
            - https://github.com/flipkart-incubator/Astra
        - Error messages include stack traces, or other sensitive information is exposed.
      - API8 - Injection
        - Client-supplied data is not validated, filtered, or sanitized by the API.
          - Astra
            - https://github.com/flipkart-incubator/Astra
        - Client-supplied data is directly used or concatenated to SQL/NoSQL/LDAP queries, OS commands, XML parsers, and Object Relational Mapping (ORM)/Object Document Mapper (ODM).
          - Astra
            - https://github.com/flipkart-incubator/Astra
        - Data coming from external systems (e.g., integrated systems) is not validated, filtered, or sanitized by the API.
      - API9 - Improper Assets Management
        - There is no documentation, or the existing documentation is not updated.
        - Hosts inventory is missing or outdated.
        - Integrated services inventory, either first- or third-party, is missing or outdated.
        - Old or previous API versions are running unpatched.
      - API10 - Insufficient Logging & Monitoring
        - It does not produce any logs, the logging level is not set correctly, or log messages do not include enough detail.
        - Log integrity is not guaranteed (e.g., Log Injection).
  - Network
    - Recon
      - Shodan
        - https://www.shodan.io/
      - Censys
        - https://censys.io/
      - BinaryEdge
        - https://app.binaryedge.io/
      - DNS Zone Transfer
        - DIG
      - Discovery
        - Enumerate DNS records
          - nmap
          - hping3
          - dns.coffee/domains
            - https://dns.coffee/domains
        - Mail Servers
        - Whois
          - http://whois.domaintools.com/
        - Traceroute
          - http://www.monitis.com/traceroute/
        - Reverse IP
        - Reverse Whois
        - Port Scanning
          - Banner Grabbing
            - wget
            - curl
          - Services running
            - Test for common/default passwords
            - Test for open vulnerabilities
            - Brute-force possible services
              - Brutus
              - THC-Hydra/XHydra
              - Ncrack
              - Patator
          - OS Fingerprinting
            - Test for open vulnerabilities
          - Open Ports
            - Masscan
              - https://github.com/robertdavidgraham/masscan
            - nmap
              - https://nmap.org/
            - Nmap Bootstrap Stylesheet
              - https://github.com/honze-net/nmap-bootstrap-xsl/
      - Automated Scanning Tools
        - OpenVAS
        - Nessus
    - Subdomain Takeover
      - tko-subs
      - HostileSubBruteForcer
        - https://github.com/nahamsec/HostileSubBruteforcer
      - SubOver
        - https://github.com/Ice3man543/SubOver
      - subjack
        - https://github.com/haccer/subjack
    - Exploit Tools
      - Metasploit
      - Evilgrade
      - JudasDNS
        - https://github.com/mandatoryprogrammer/JudasDNS
    - SSL Checks
      - sslscan
      - Heartbleed
      - POODLE
      - DROWN
    - TLS ROBOT
    - Bash ShellShock
    - Sniffing
      - Wireshark
      - Dsniff
      - Bettercap
- MobileApplication
  - OWASP 2016
    - M1 - Improper Platform Usage
    - M2 - Insecure Data Storage
    - M3 - Insecure Communication
    - M4 - Insecure Authentication
    - M5 - Insufficient Cryptography
    - M6 - Insecure Authorization
    - M7 - Client Code Quality
    - M8 - Code Tampering
    - M9 - Reverse Engineering
    - M10 - Extraneous Functionality
  - iOS
  - Android
- Internet of Things
  - Recon
    - External
      - fccid.io
        - Does it reveal details about the target?
        - Identify chipsets being used
        - Identify exposed interfaces
        - Check for internal and external pictures
        - Test cases on the device
        - Find on which frequency is being used
      - Identify ports and interfaces
      - Check voltage and power consumption
    - Internal
      - Identify chips
      - Identify other components
      - Copper tracing
    - Identify the pinouts for the Serial interface
      - Multimeter
      - Logic analyzer
      - JTAGulator
  - Testing
    - Connect to the Serial interface
      - Identify the baudrate
      - Shell
        - Authenticated
          - Dump the firmware
          - Modify values on the device and see if it persists
          - Control the device via Shell
          - Does shell have root privileges?
        - Unauthenticated
          - Can you brute-force the password?
          - Is the password hidden in the firmware?
          - Bootloader manipulation attacks
    - Analyze firmware
      - Is the firmware encrypted?
        - What kind of encryption is being used?
          - hexdump
          - strings
          - binwalk
      - Extracting components from the firmware
        - Extract the file system
          - binwalk
        - Find hardcoded credentials
          - API keys
          - Private certificates
          - Backdoor
          - Config files
      - Emulating the firmware
        - Identify the architecture
        - Emulate the firmware
          - Qemu
          - Chroot
          - FAT
        - Perform analysis and exploitation via emulation
      - Reverse Engineering firmware binaries
        - Test for command injection bugs
          - IDA analysis
          - Web files
        - Identify buffer overflows and other binary vulns and exploitation
      - Automated Scanning Tools
        - Firmwalker
    - Communication with Mobile and Web applications
      - Reverse Engineer the Mobile Application
        - Search for ports being used
          - JADx
          - APKTool
        - Search for hardcoded firmware download URLs
          - JADx
          - APKTool
        - Identify command messaging format
          - JADx
          - APKTool
        - Search for hardcoded SSIDs
          - JADx
          - APKTool
        - Search for hardcoded encryption keys
          - JADx
          - APKTool
      - Intercept the traffic
        - Search and Analyze the traffic between devices
      - MQTT
        - What topic are being used?
        - Can you subscribe to any topic?
        - Can you publish to the topics?
        - Is there authentication being used?
      - CoAP
        - Is the implementation secure?
    - Radio Security
      - Identify spikes in the frequency used when data is being transferred
        - GQRX
      - Bluetooth
        - BLE
          - Scan for devices
            - Bettercap
              - https://github.com/bettercap/bettercap
            - Blue Hydra
              - https://github.com/pwnieexpress/blue_hydra
            - btlejack
              - https://github.com/virtualabs/btlejack
          - Try to sniff the communication
            - Wireshark
              - btlejack
                - https://github.com/virtualabs/btlejack
              - Adafruit BLE Sniffer
              - Ubertooth
                - https://github.com/greatscottgadgets/ubertooth
          - Identify the handles being read and written
            - Bettercap
              - https://github.com/bettercap/bettercap
          - Can you write handles?
            - gatttool
            - btlejack
              - https://github.com/virtualabs/btlejack
          - Are replay attacks possible?
            - BTLEJuice
              - https://github.com/DigitalSecurity/btlejuice
            - gattacker
              - https://github.com/securing/gattacker
          - Is the communication encrypted?
            - Yes
              - Did you caputred the inital key exchange communication?
              - Can you decrypt the communication by brute-forcing?
                - crackle
                  - https://github.com/mikeryan/crackle
            - No
              - Is sensitive information is being passed in clear text?
        - Classic
      - ZigBee
        - Identify channel ZigBee is communicating
          - zbstumbler
        - Try to sniff the communication
          - zbdump
          - zbwireshark
        - Is the communication encrypted?
        - Can you capture the key exchange or found the key on the device or firmware?
        - Are you able to decrypt the communication
        - Are replay attacks possible?
          - zbreplay
      - Wi-Fi
        - Signal processing blocks to implement software radios
          - GNURadio
- Logical
  - Founded
    - What date was the company founded?
  - Competitors
    - Grab the case studies the target have published and gather some inside information
  - Case Studies
    - Grab the case studies the target have published and gather some inside information
  - Employees
    - Linkedin
    - Github
      - github.com/search?q= {COMPANY_NAME}-&type=Users
  - Funding Rounds
  - Stackshare
  - Job Positions
    - Indeed
    - Linkedin
    - Monster
    - Glassdoor
    - Jobvite
    - Greenhouse
  - Public legal records
    - https://publicrecords.netronline.com/
  - OpenSecrets
    - https://www.opensecrets.org/
  - Partners
    - List all the partners the target has
      - Google
      - Linkedin
  - Investors
    - Crunchbase
  - Misc
    - Phone Lookup
    - License Plate Lookup
    - Search People
  - People search engine
    - pipl.com
      - https://pipl.com/
    - sync.me
      - https://sync.me/
    - truecaller.com
      - https://www.truecaller.com/
    - trape
      - https://github.com/jofpin/trape
- Physical
  - Offices
  - Datacenter Locations
  - Third-Party Service Providers
  - Surveillance
    - Cameradar
      - https://github.com/Ullaakut/cameradar
    - kamerka
      - https://github.com/woj-ciech/kamerka

Presented with xmind